whoo
App 檢測

第4組

資三A 11116148 陳宗奇　資三A 12156107 張乃云

資三A 11156143 吳泯樺　資三A 12156108 劉憶瑩

資三A 12156102 簡偉玲　資三A 12156162 王海悅



目錄



一、簡介 App
二、使用心得
三、檢測分層
四、檢測項目
五、檢測內容說明
六、心得與收穫
七、分工

一、簡介 App：whoo 是什麼？

是一款免費的 iOS / Android 社交定位 App，

使用者可以在地圖上即時查看好友位置，

並顯示好友的手機剩餘電量與停留時間

此外，Whoo 也提供模糊位置與凍結位置設定，

讓使用者在互動與隱私之間取得平衡



二、使用心得



操作介面相當直覺，

不需要花太多時間就能理解各項功能。



在和朋友相約或確認對方狀況時，

即時定位與電量顯示都相當實用，



加入貼圖互動與隱私設定後，

使用起來不會有被過度追蹤的壓力

三、檢測層級

適合的檢測層級

綜合觀察這個 App 的功能，我們覺得它比較適合做

L2：需要使用者身分驗證的 App 的檢測

因為使用者在使用主要功能或看個人資料之前，

都要先登入、驗證身分，

這就符合 L2 對「身分鑑別」的要求



三、檢測層級

其他層級之排除理由

L1 層級適用於無須使用者身分鑑別的App,
然而本 App 涉及個人化設定與私密資料存取,
若僅以 L1 標準進行檢測,
將無法完整驗證身分鑑別相關機制的安全性

L3 層級主要針對含有交易行為的App,
本 App 並未涉及金流支付、點數或虛擬交易,
因此無須提升至最嚴格的L3 檢測層級

四、檢測項目

L2必要之檢測項目

4.1.1.1.2、4.1.1.3.1、4.1.2.1.1、4.1.2.1.2、4.1.2.3.1、
4.1.2.3.2、4.1.2.3.4、4.1.2.3.6、4.1.2.3.7、4.1.2.3.8、
4.1.2.4.1、4.1.2.5.1、4.1.2.5.2、4.1.2.5.3、4.1.4.1.1、
4.1.4.1.2、4.1.4.2.1、4.1.4.2.2、4.1.4.2.3、4.1.5.1.1、
4.1.5.1.2、4.1.5.3.1、4.1.5.4.1、4.1.5.4.2、4.2.2.1.2

四、檢測項目

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.1.行動應用程式發布安全	4.1.1.1.行動應用程式發布	—	—	—	4.1.1.1.1.行動應用程式應於可信任來源之行動應用程式商店發布
		★	★	★	4.1.1.1.2.行動應用程式應於發布時說明欲存取之安全敏 感性資料、行動裝置資源及宣告之權限用途
	4.1.1.2.行動應用程式更新	—	—	—	4.1.1.2.1.行動應用程式應於可信任來源之行動應用程式 商店發布更新
		—	—	—	4.1.1.2.2.行動應用程式應提供更新機制
		—	—	—	4.1.1.2.3.行動應用程式應於安全性更新時主動公告
	4.1.1.3.行動應用程式安全性問題回報	★	★	★	4.1.1.3.1.行動應用程式開發者應提供回報安全性問題之管道
		—	—	—	4.1.1.3.2.行動應用程式開發者應於適當之期間內回覆問題並改善

不易判斷

四、檢測項目

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.2.安全敏感性資料保護	4.1.2.1.安全敏感性資料蒐集	★	★	★	4.1.2.1.1.行動應用程式應於蒐集安全敏感性資料前，取得使用者同意 ✔
		★	★	★	4.1.2.1.2.行動應用程式應提供使用者拒絕蒐集安全敏感性資料之權利 ✔
	4.1.2.2.安全敏感性資料利用	—	—	—	4.1.2.2.1.行動應用程式應於使用安全敏感性資料前，取得使用者同意 ✔
		—	—	—	4.1.2.2.2.行動應用程式應提供使用者拒絕使用安全敏感性資料之權利 ✔
		—	—	—	4.1.2.2.3.行動應用程式如採用通行碼認證，應主動提醒使用者設定較複雜之通行碼 X
		—	—	—	4.1.2.2.4.行動應用程式應提醒使用者定期更改通行碼 不易判斷

四、檢測項目

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.2. 安全敏感性資料保護	4.1.2.3. 安全敏感性資料儲存	★	★	★	4.1.2.3.1. 行動應用程式應於儲存安全敏感性資料前，取得使用者同意
		★	★	★	4.1.2.3.2. 行動應用程式應提供使用者拒絕儲存安全敏感性資料之權利
		—	—	—	4.1.2.3.3. 行動應用程式儲存之安全敏感性資料，應僅用於其使用聲明之用途
		★	★	—	4.1.2.3.4. 行動應用程式應避免在關閉及登出後將安全敏感性資料儲存於冗餘檔案或日誌檔案中
		—	—	★	4.1.2.3.5. 行動應用程式應避免將安全敏感性資料儲存於冗餘檔案或日誌檔案中
		★	★	★	4.1.2.3.6. 安全敏感性資料應採用適當且有效之金鑰長度與加密演算法，進行加密處理再儲存
		★	★	★	4.1.2.3.7. 安全敏感性資料應儲存於受作業系統保護之區域，以防止其他應用程式未經授權之存取
		★	★	★	4.1.2.3.8. 安全敏感性資料應避免出現於行動應用程式之程式碼
		—	—	★	4.1.2.3.9. 行動應用程式於非使用者主動進行的畫面擷取 時應主動警示使用

不易判斷

四、檢測項目

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.2.安全敏感性資料保護	4.1.2.4.安全敏感性資料傳輸	★	★	★	4.1.2.4.1.行動應用程式透過網路傳輸安全敏感性資料，應使用適當且有效之金鑰長度與加密演算法進行安全加密。
	4.1.2.5.安全敏感性資料分享	★	★	★	4.1.2.5.1.行動裝置內之不同行動應用程式間，應於分享安 全敏感性資料前，取得使用者同意
		★	★	★	4.1.2.5.2.行動應用程式應提供使用者拒絕分享安全敏感性資料之權利
		★	★	★	4..1.2.5.3.行動應用程式分享安全敏感性資料時，應避免未授權之行動應用程式存取
	4.1.2.6.安全敏感性資料刪除	—	—	—	4.1.2.6.1.行動應用程式如涉及儲存使用者安全敏感性資 料，應提供使用者刪除之功能

四、檢測項目

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.4.行動應用程式使用者身分鑑別、授權與連線管理安全	4.1.4.1.使用者身分鑑別與授權	—	★	★	4.1.4.1.1.行動應用程式應有適當之身分鑑別機制，確認使用者身分 ✔
		—	★	★	4.1.4.1.2.行動應用程式應依使用者身分授權 不易判斷
	4.1.4.2.連線管理機制	—	★	★	4.1.4.2.1.行動應用程式應避免使用具有規則性之交談識別碼 X
		★	★	★	4.1.4.2.2.行動應用程式應確認伺服器憑證之有效性 ✔
		★	★	★	4.1.4.2.3.行動應用程式應確認伺服器憑證為可信任之憑證機構所簽發 ✔

四、檢測項目

資訊安全技術要求面向	資訊安全技術要求事項	各類型之行動應用程式必要符合檢測項目			技術要求
		L1	L2	L3	
4.1.5.行動應用程式碼安全	4.1.5.1.防範惡意程式碼與避免資訊安全漏洞	★	★	★	4.1.5.1.1.行動應用程式應避免含有惡意程式碼 ✓
		★	★	★	4.1.5.1.2.行動應用程式應避免資訊安全漏洞 X
	4.1.5.2.行動應用程式完整性	—	—	—	4.1.5.2.1.行動應用程式應使用適當且有效之完整性驗證機制，以確保其完整性。 X
	4.1.5.3.函式庫引用安全	★	★	★	4.1.5.3.1.行動應用程式於引用之函式庫有更新時，應備妥對應之更新版本，更新方式請參酌 4.1.1.行動應用程式發布安全 ✓
	4.1.5.4.使用者輸入驗證	★	★	★	4.1.5.4.1.行動應用程式應針對使用者於輸入階段之字串，進行安全檢查 X
		★	★	★	4.1.5.4.2.行動應用程式應提供相關注入攻擊防護機制 X

四、檢測項目

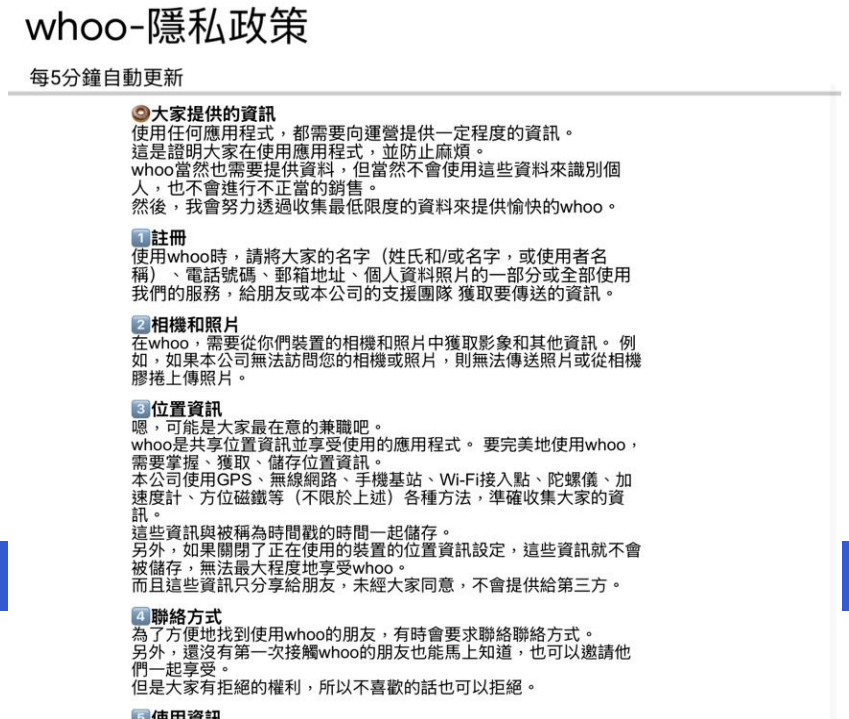
資訊安全技術要求面向	資訊安全技術要求事項	各類型之行動應用程式必要符合檢測項目			技術要求
		L1	L2	L3	
4.2.2. 伺服器端安全檢測	4.2.2.1. Webview 安全檢測	–	–	–	4.2.2.1.1.行動應用程式應使用 Webview 與遠端伺服器進行網頁資源交換 ✔
		★	★	★	4.2.2.1.2.行動應用程式於 Webview 呈現功能時，所連線之網域應為安全網域 ✔

五、檢測內容說明

(v)4.1.1.1.1.行動應用程式應於可信任來源之行動應用程式商店發布 **appstore上發布**



(v)4.1.1.1.2.行動應用程式應於發布時說明欲存取之安全敏感性資料、行動裝置資源及宣告之權限用途 **於appstore上可找到資料用途**



whoo-隱私政策

每5分鐘自動更新

大家提供的資訊
使用任何應用程式，都需要向運營提供一定程度的資訊。
這是證明大家在使用應用程式，並防止麻煩。
whoo當然也需要提供資料，但當然不會使用這些資料來識別個人，也不會進行不正當的銷售。
然後，我會努力透過收集最低限度的資料來提供愉快的whoo。

1 註冊
使用whoo時，請將大家的名字（姓氏和/或名字，或使用者名稱）、電話號碼、郵箱地址、個人資料照片的一部分或全部使用我們的服務，給朋友或本公司的支援團隊 獲取要傳送的資訊。

2 相機和照片
在whoo，需要從你們裝置的相機和照片中獲取影象和其他資訊。 例如，如果本公司無法訪問您的相機或照片，則無法傳送照片或從相機膠捲上傳照片。

3 位置資訊
嗯，可能是大家最在意的兼職吧。
whoo是共享位置資訊並享受使用的應用程式。 要完美地使用whoo，需要掌握、獲取、儲存位置資訊。
本公司使用GPS、無線網路、手機基站、Wi-Fi接入點、陀螺儀、加速度計、方位磁鐵等（不限於上述）各種方法，準確收集大家的資訊。
這些資訊與被稱為時間戳的時間一起儲存。
另外，如果關閉了正在使用的裝置的位置資訊設定，這些資訊就不會被儲存，無法最大程度地享受whoo。
而且這些資訊只分享給朋友，未經大家同意，不會提供給第三方。

4 聯絡方式
為了方便地找到使用whoo的朋友，有時會要求聯絡聯絡方式。
另外，還沒有第一次接觸whoo的朋友也能馬上知道，也可以邀請他們一起享受。
但是大家有拒絕的權利，所以不喜歡的話也可以拒絕。

五、檢測內容說明

(v)4.1.1.2.1.行動應用程式應於可信任來源之行動應用程式商店發布更新　**更新紀錄**

(v)4.1.1.2.2.行動應用程式應提供更新機制

(v)4.1.1.2.3.行動應用程式應於安全性更新時主動公告

版本記錄

0.40.4 5 天前

我們把足跡改成了方塊顯示，變得更好看也更清楚了！
覺得如何？

0.40.3 1 週前

我們已經解決了訂閱錯誤！

0.40.2 1 週前

修復了錯誤！！！

0.40.1 2 週前

點擊地標即可觀看特別影片！
在 whoo 搖一搖手機就會觸發效果！
讓群組聊天室更好用了！

0.40.0 3 週前

我们终于做出了制霸率功能！请尽情享受吧！

0.39.9 3 週前

修復了各種錯誤。

0.39.8 4 週前

已修復地圖變得卡頓的錯誤

0.39.7 1 個月前

讓原創貼圖更容易使用。

五、檢測內容說明

(v)4.1.1.3.1. 行動應用程式開發者應提供回報安全性問題之管道　**設置管道可與負責人聯繫**



4.1.1.3.2. 行動應用程式開發者應於適當之期間內回覆問題並改善

因無實際去反應故無法判斷官方會於多久回覆

不易判斷

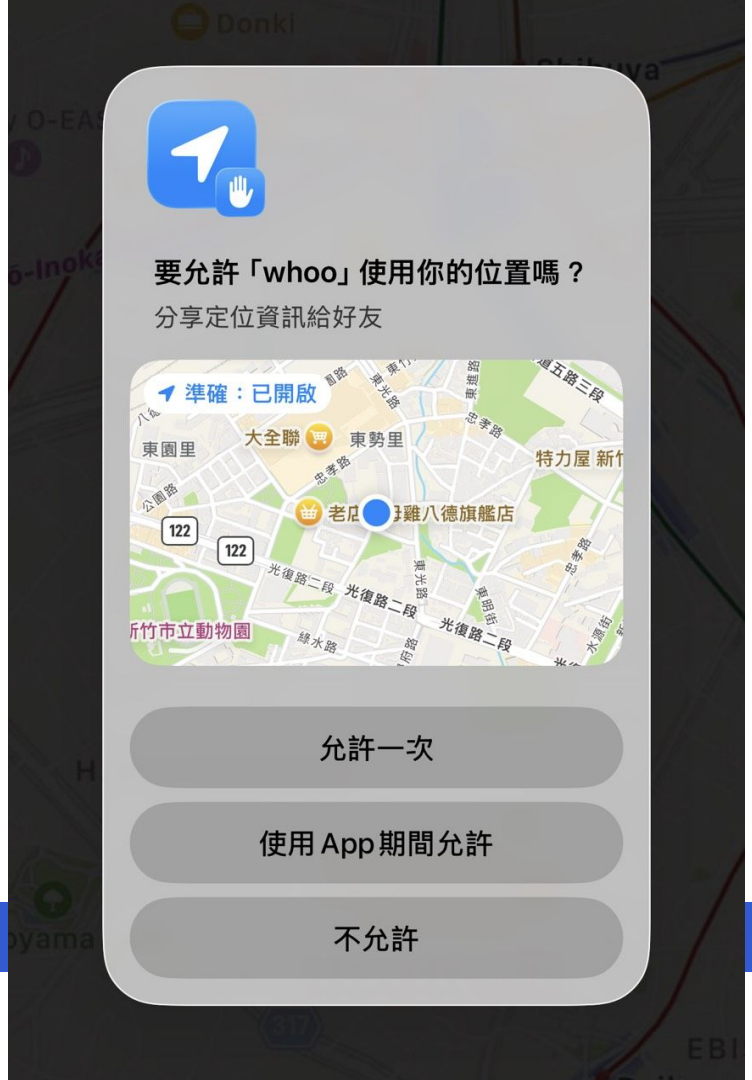
資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.1.行動應用程式發布安全	4.1.1.1.行動應用程式發布	—	—	—	4.1.1.1.1.行動應用程式應於可信任來源之行動應用程式商店發布
		★	★	★	4.1.1.1.2.行動應用程式應於發布時說明欲存取之安全敏 感性資料、行動裝置資源及宣告之權限用途
	4.1.1.2.行動應用程式更新	—	—	—	4.1.1.2.1.行動應用程式應於可信任來源之行動應用程式 商店發布更新
		—	—	—	4.1.1.2.2.行動應用程式應提供更新機制
		—	—	—	4.1.1.2.3.行動應用程式應於安全性更新時主動公告
	4.1.1.3.行動應用程式安全性問題回報	★	★	★	4.1.1.3.1.行動應用程式開發者應提供回報安全性問題之管道
		—	—	—	4.1.1.3.2.行動應用程式開發者應於適當之期間內回覆問題並改善

不易判斷

五、檢測內容說明

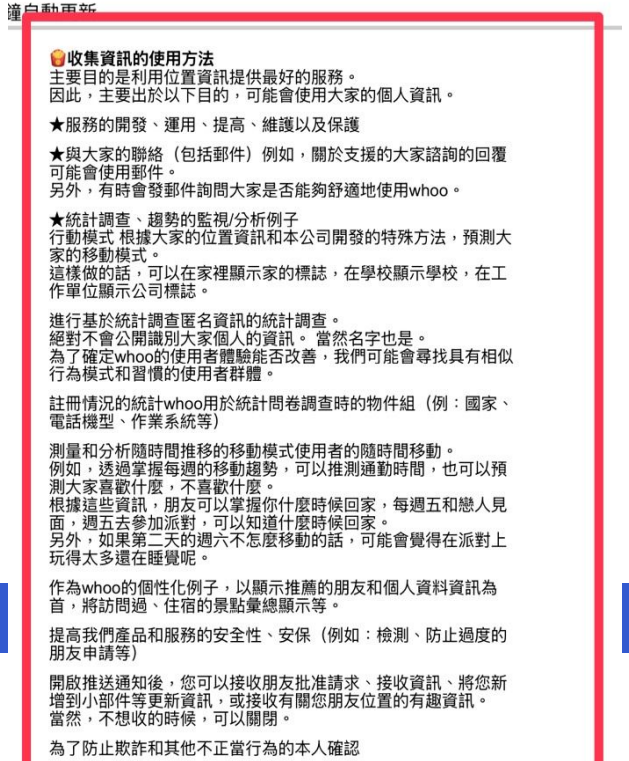
(v)4.1.2.1.1.行動應用程式應於蒐集安全敏感性資料前,取得使用者同意

(v)4.1.2.1.2. 行動應用程式應提供使用者拒絕蒐集安全敏感性資料之權利



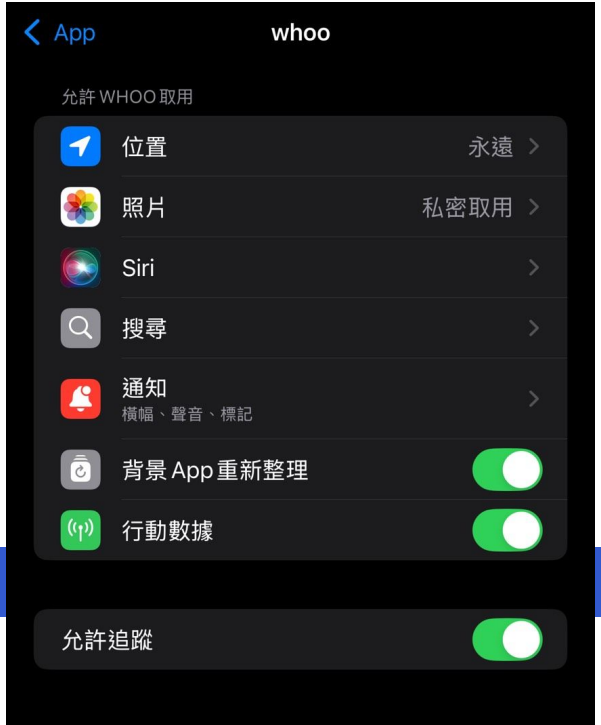
五、檢測內容說明

(v)4.1.2.2.1. 行動應用程式應於使用安全敏感性資料前,取得使用者同意



(v)4.1.2.2.2. 行動應用程式應提供使用者拒絕使用安全敏感性資料之權利

設定截圖顯示可關閉定位、照片、通知等權限



五、檢測內容說明

(x)4.1.2.2.3.行動應用程式如採用通行碼認證，應主動提醒使用者設定較複雜之通行碼 **未提醒**



4.1.2.2.4.行動應用程式應提醒使用者定期更改通行碼 **使用期間短無發現**

不易判斷

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.2.安全敏感性資料保護	4.1.2.1.安全敏感性資料蒐集	★	★	★	4.1.2.1.1.行動應用程式應於蒐集安全敏感性資料前，取得使用者同意 ✔
		★	★	★	4.1.2.1.2.行動應用程式應提供使用者拒絕蒐集安全敏感性資料之權利 ✔
	4.1.2.2.安全敏感性資料利用	—	—	—	4.1.2.2.1.行動應用程式應於使用安全敏感性資料前，取得使用者同意 ✔
		—	—	—	4.1.2.2.2.行動應用程式應提供使用者拒絕使用安全敏感性資料之權利 ✔
		—	—	—	4.1.2.2.3.行動應用程式如採用通行碼認證，應主動提醒使用者設定較複雜之通行碼 ✘
		—	—	—	4.1.2.2.4.行動應用程式應提醒使用者定期更改通行碼 不易判斷

五、檢測內容說明

(v)4.1.2.3.1.行動應用程式應於儲存安全敏感性資料前，取得使用者同意

於許可協議說明

(v)4.1.2.3.2.行動應用程式應提供使用者拒絕儲存安全敏感性資料之權利

於許可協議說明



7 個人資訊的處理

1. 除了本條款和條件外，我們將按照我們的隱私權政策處理個人資訊等。

2. 在使用或檢視本服務之前，使用者必須查看本服務的隱私權政策並同意其內容。

3. 本公司可能會將透過本服務所獲得的個人資訊用於隱私權政策中規定的目的以及提供本服務的一般用途。

4. 使用者在處理透過本服務所獲得的個人資訊時，應遵守《個人資訊保護法》及其他法律法規。

4.1.2.3.3.行動應用程式儲存之安全敏感性資料，應僅用於其使用聲明之用途

難以判斷開發者是否有將資料用於非聲明之用途

不易判斷

五、檢測內容說明

(x)4.1.2.3.4.行動應用程式應避免在關閉及登出後將安全敏感性資料儲存於冗餘檔案或日誌檔案中
(x)4.1.2.3.5.行動應用程式應避免將安全敏感性資料儲存於冗餘檔案或日誌檔案中

NO	ISSUE	嚴重程度	標準	文件	選項
1	該應用程式會記錄資訊。敏感資訊絕不應該被記錄。	資訊	**CWE：** CWE-532：將敏感資訊插入日誌檔案 **OWASP MASVS：** MSTG-STORAGE-3	顯示文件	

五、檢測內容說明

(v)4.1.2.3.6.安全敏感性資料應採用適當且有效之金鑰長度與加密演算法，進行加密處理再儲存

不	問題	嚴重程度	標準
11	This App uses SQL Cipher. SQLCipher provides 256-bit AES encryption to sqlite database files.	info	**OWASP MASVS:** MSTG-CRYPTO-1

(v)4.1.2.3.7.安全敏感性資料應儲存於受作業系統保護之區域，以防止其他應用程式未經授權之存取

使用了 SQL Cipher，資料庫預設會存在受保護的 App 私有區域，這符合本項要求

2. 判斷理由與證據

這項規範要求 App 對於「儲存」的敏感資料，必須使用「適當且有效」的加密演算法（如 AES 等）與金鑰長度。在您的掃描報告中，第 9 項提供了直接且強力的正面證據：

- **關鍵證據 (MobSF 第 9 項)：** 「This App uses **SQL Cipher**. SQLCipher provides **256-bit AES encryption** to sqlite database files.」
- **技術分析：**
  - **演算法有效性：** 報告明確指出使用了 **AES-256** 加密演算法。AES-256 是目前全球公認安全性極高、符合國際資安標準的對稱式加密演算法。
  - **金鑰長度：** 256 位元的金鑰長度完全符合規範中「適當且有效之金鑰長度」的要求。
  - **實作對象：** 該技術應用於 SQLite 資料庫檔案，確保資料在寫入手機儲存空間（Disk）前已經過加密處理，直接達成「加密處理再儲存」的規範目的。

檢測項目 4.1.2.3.6： 符合。 **佐證說明：**

1. 根據 MobSF 靜態分析報告（No. 9）顯示，本應用程式已整合 **SQLCipher** 資料庫加密套件。
2. 該套件針對本機端的 SQLite 資料庫檔案提供 **256-bit AES** 高強度加密保護。
3. 經確認，敏感性資料於儲存時皆已透過上述適當且有效之演算法進行加密，安全性足以防範未經授權之資料讀取，符合規範要求。

五、檢測內容說明

(x)4.1.2.3.8.安全敏感性資料應避免出現於行動應用程式之程式碼

3	文件可能包含硬編碼的敏感訊息，例如使用者名稱、密碼、金鑰等。	警告	**CWE：** CWE-312：敏感資訊的明文儲存； **OWASP Top 10：** M9：逆向工程； **OWASP MASVS：** MSTG-STORAGE-14

2. 哪一項才符合 4.1.2.3.8？

您的掃描結果中，**第三項**才是直接對應 4.1.2.3.8 的項目：

- **掃描結果第三項：**「Files may contain **hardcoded** sensitive information like usernames, passwords, keys etc.」（檔案可能包含**硬編碼**的敏感資訊，例如使用者名稱、密碼、金鑰等。）
- **對應邏輯：**「Hardcoded（硬編碼）」指的就是直接寫在**程式碼**裡的資料。因此，第三項的警告正是在提醒您違反了 4.1.2.3.8 的規定。

(v)4.1.2.3.9. 行動應用程式於非使用者主動進行的畫面擷取時應主動警示使用者

android.permission.DETECT_SCREEN_CAPTURE	普通的	當嘗試對應用程式視窗進行螢幕截圖時發出通知。	允許應用程式在有人嘗試對其視窗進行螢幕截圖時收到通知。

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.2. 安全敏感性資料保護	4.1.2.3. 安全敏感性資料儲存	★	★	★	4.1.2.3.1. 行動應用程式應於儲存安全敏感性資料前，取得使用者同意
		★	★	★	4.1.2.3.2. 行動應用程式應提供使用者拒絕儲存安全敏感性資料之權利
		—	—	—	4.1.2.3.3. 行動應用程式儲存之安全敏感性資料，應僅用於其使用聲明之用途
		★	★	—	4.1.2.3.4. 行動應用程式應避免在關閉及登出後將安全敏感性資料儲存於冗餘檔案或日誌檔案中
		—	—	★	4.1.2.3.5. 行動應用程式應避免將安全敏感性資料儲存於冗餘檔案或日誌檔案中
		★	★	★	4.1.2.3.6. 安全敏感性資料應採用適當且有效之金鑰長度與加密演算法，進行加密處理再儲存
		★	★	★	4.1.2.3.7. 安全敏感性資料應儲存於受作業系統保護之區域，以防止其他應用程式未經授權之存取
		★	★	★	4.1.2.3.8. 安全敏感性資料應避免出現於行動應用程式之程式碼
		—	—	★	4.1.2.3.9. 行動應用程式於非使用者主動進行的畫面擷取 時應主動警示使用者

不易判斷

五、檢測內容說明

(v)4.1.2.4.1.行動應用程式透過網路傳輸安全敏感性資料，應使用適當且有效之金鑰長度與加密演算法進行安全加密

不	問題	嚴重程度	標準	文件	選項
11	此應用程式使用 SQL Cipher。 SQLCipher 為 sqlite 資料庫檔案提供 256 位元 AES 加密。	資訊	**OWASP MASVS：** MSTG-CRYPTO-1	net/sqlcipher/database/SupportHelper.java	

(x)4.1.2.5.1.行動裝置內之不同行動應用程式間，應於分享安全敏感性資料前，取得使用者同意

未經過同意但是其他應用程式可以存取資料　舉例分享給 LINE 應該跳小視窗詢問

(x)4.1.2.5.2.行動應用程式應提供使用者拒絕分享安全敏感性資料之權利

未有拒絕權利其他應用程式可以存取資料

10	此應用程式會將資料複製到剪貼簿。請勿將敏感資料複製到剪貼簿，因為其他應用程式可以存取這些資料。	資訊	**OWASP MASVS：** MSTG-STORAGE-10	app/whoo/debugMenu/DebugMenuFragment.java app/whoo/ui/message/MessageListAdapter.java	

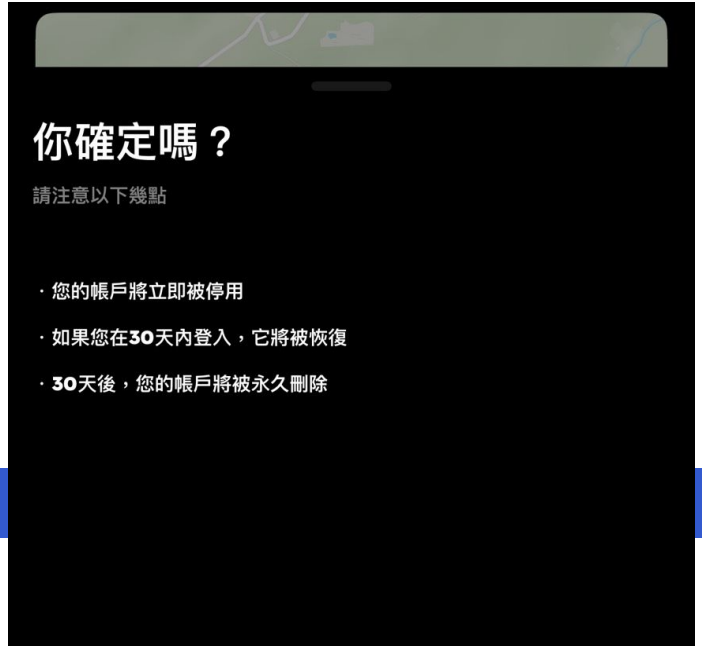
五、檢測內容說明

(x)4.1.2.5.3.行動應用程式分享安全敏感性資料時，應避免未授權之行動應用程式存取

10	此應用程式會將資料複製到剪貼簿。請勿將敏感資料複製到剪貼簿，因為其他應用程式可以存取這些資料。	info	**OWASP MASVS：** MSTG-STORAGE-10	app/whoo/debugMenu/DebugMenuFragment.java app/whoo/ui/message/MessageListAdapter.java	

(v)4.1.2.6.1.行動應用程式如涉及儲存使用者安全敏感性資料，應提供使用者刪除之功能

可以刪除帳戶，資料於30日後消失



資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.2.安全敏感性資料保護	4.1.2.4.安全敏感性資料傳輸	★	★	★	4.1.2.4.1.行動應用程式透過網路傳輸安全敏感性資料，應使用適當且有效之金鑰長度與加密演算法進行安全加密。
	4.1.2.5.安全敏感性資料分享	★	★	★	4.1.2.5.1.行動裝置內之不同行動應用程式間，應於分享安 全敏感性資料前，取得使用者同意
		★	★	★	4.1.2.5.2.行動應用程式應提供使用者拒絕分享安全敏感性資料之權利
		★	★	★	4..1.2.5.3.行動應用程式分享安全敏感性資料時，應避免未授權之行動應用程式存取
	4.1.2.6.安全敏感性資料刪除	—	—	—	4.1.2.6.1.行動應用程式如涉及儲存使用者安全敏感性資 料，應提供使用者刪除之功能

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.3.交易資源控管安全	4.1.3.1.交易資源使用	–	–	★	4.1.3.1.1.行動應用程式應於使用交易資源時主動通知使 用者
		–	–	★	4.1.3.1.2.行動應用程式應提供使用者拒絕使用交易資源 之權利
	4.1.3.2.交易資源控管	–	–	★	4.1.3.2.1.行動應用程式應於使用交易資源時進行使用者 身分鑑別
		–	–	★	4.1.3.2.2.行動應用程式應記錄使用之交易資源與時間

未有交易系統故不提

五、檢測內容說明

(v) 4.1.4.1.1.行動應用程式應有適當之身分鑑別機制, 確認使用者身分

可用email驗證



五、檢測內容說明

(v)4.1.4.1.2.行動應用程式應依使用者身分授權

具備傳遞授權資訊的能力：在 `applyHeadersAndMethod` 函式中，程式碼會遍歷 `httpRequest.getHeaders()` 並透過 `setRequestProperty` 將所有 Header 資訊加入連線

這意味著如果上層模組傳入身分權杖 (Token)，此類別能正確地將其發送至伺服器進行身分比對

判定總結與證明建議

判定目標	建議引用程式碼行數
身分授權發送	81 - 99 行
授權資訊保護	135 - 144 行

```
}

HttpURLConnection applyHeadersAndMethod(HttpRequest httpRequest, HttpURLConnection httpURLConnection) throws ProtocolException {
    return applyHeadersAndMethod(httpRequest, httpURLConnection, null);
}

HttpURLConnection applyHeadersAndMethod(HttpRequest httpRequest, HttpURLConnection httpURLConnection, CurlBuilder curlBuilder) throws ProtocolException {
    if (httpRequest.getHeaders() != null && !httpRequest.getHeaders().isEmpty()) {
        if (curlBuilder != null) {
            curlBuilder.setHeaders(httpRequest.getHeaders());
        }
        for (Map.Entry<String, String> entry : httpRequest.getHeaders().entrySet()) {
            String key = entry.getKey();
            if (!key.equals("Content-Length") && !key.equals("Host")) {
                key.equals("Expect");
                httpURLConnection.setRequestProperty(key, entry.getValue());
            }
        }
    }
    String method = httpRequest.getMethod();
    httpURLConnection.setRequestMethod(method);
    if (curlBuilder != null) {
        curlBuilder.setMethod(method);
    }
    return httpURLConnection;
}
```

五、檢測內容說明

(x)4.1.4.2.1.行動應用程式應避免使用具有規則性之交談識別碼

5	該應用程式使用不安全的隨機數產生器。	警告	**CWE：** CWE-330：使用隨機性不足的值； **OWASP Top 10：** M5：加密不足； **OWASP MASVS：** MSTG-CRYPTO-6

1. 判定結果：不通過 (存在缺失)

2. 判斷理由與證據

這項規範要求行動應用程式在連線管理上，應避免產生可被預測或具有規則性的「交談識別碼」(Session ID / Token)。根據掃描結果，該 App 存在以下核心技術缺陷：

- **關鍵證據 (MobSF 第 5 項)：** 「The App uses an **insecure Random Number Generator**」。
- **技術關聯性：**
  - **規則性風險**：交談識別碼的安全性建立在「不可預測性」上。如果程式使用不安全的隨機數產生器（例如 Java 的 `java.util.Random` 而非 `SecureRandom`），產生的識別碼將具有統計學上的規則性。
  - **劫持風險**：攻擊者若能推算出識別碼的產生規律，就能偽造有效的交談識別碼，進而冒充使用者身分進行連線，這直接違反了 **4.1.4.2.1** 的安全要求。

檢測項目 4.1.4.2.1： 不通過。 **佐證說明：**

1. 根據靜態分析掃描結果（No. 5），該應用程式使用了不安全之隨機數產生器 (Insecure Random Number Generator)。
2. 由於隨機數產生機制不夠嚴謹，將導致其產生的交談識別碼 (Session ID/Token) 具有可預測之規則性。
3. 攻擊者可能藉此推算並偽造識別碼，造成連線管理機制之失效，不符合規範要求。

五、檢測內容說明

(v)4.1.4.2.2.行動應用程式應確認伺服器憑證之有效性

CERTIFICATE ANALYSIS

HIGH	WARNING	資訊
0	0	1

Search:

TITLE	SEVERITY	DESCRIPTION
已簽署的申請	info	應用程式已使用代碼簽名證書進行簽名

Showing 1 to 1 of 1 entries

以前的 1 Next

9	此應用程式使用 SSL 憑證固定技術來偵測或阻止安全通訊通道中的中間人攻擊。	安全的	**OWASP MASVS：** MSTG-NETWORK-4	app/whoo/di/NetworkModule.java ch/qos/logback/core/net/ssl/SSLContextFactoryBean.java

SSL Pinning 是一種更高等級的有效性確認
它不只檢查憑證是否過期，還檢查憑證是否為 App 預設的那一張

五、檢測內容說明

(v)4.1.4.2.3.行動應用程式應確認伺服器憑證為可信任之憑證機構所簽發



CERTIFICATE ANALYSIS

HIGH	WARNING	資訊
0	0	1

Search:

TITLE	SEVERITY	DESCRIPTION
已簽署的申請	info	應用程式已使用代碼簽名證書進行簽名

Showing 1 to 1 of 1 entries

Pinning 技術直接在 App 內部比對憑證特徵，確保連線對象絕對是開發者指定的伺服器，能有效落實此項 目的安全目的

SSL Pinning 的做法：App 內部直接寫死（Hardcode）或儲存了特定的憑證資訊（例如憑證的公鑰雜湊 值）。

結果：當 App 進行連線時，它會檢 查伺服器回傳的憑證是否與內建的資訊完全吻合。因為開發者只會把「由可信任機構簽發給 自己公司」的憑證綁定在 App 裡，所以這項技術從根本上確保了連線對象 絕對是經過驗證的正確機構

資訊安全技術要求面相	資訊安全技術要求事項	各類型之行動應用程式必要府和檢測項目			技術要求
		L1	L2	L3	
4.1.4.行動應用程式使用者身分鑑別、授權與連線管理安全	4.1.4.1.使用者身分鑑別與授權	—	★	★	4.1.4.1.1.行動應用程式應有適當之身分鑑別機制，確認使用者身分 ✓
		—	★	★	4.1.4.1.2.行動應用程式應依使用者身分授權 ✓
	4.1.4.2.連線管理機制	—	★	★	4.1.4.2.1.行動應用程式應避免使用具有規則性之交談識別碼 X
		★	★	★	4.1.4.2.2.行動應用程式應確認伺服器憑證之有效性 ✓
		★	★	★	4.1.4.2.3.行動應用程式應確認伺服器憑證為可信任之憑證機構所簽發 ✓

五、檢測內容說明

(v)4.1.5.1.1.行動應用程式應避免含有惡意程式碼



在MobSF 掃描結果摘要中，並未出現任何關於「 Malware（惡意軟體）」、「Virus（病毒）」或「 Trojan（木馬）」的偵測警報
MobSF 主要偵測已知的惡意特徵碼
由於報告中未列出惡意程式相關 Issue，可判定為符合此項基本要求

五、檢測內容說明

(x)4.1.5.1.2.行動應用程式應避免資訊安全漏洞

2	應用程式可以對外部儲存設備進行讀寫操作。任何應用程式都可以讀取寫入外部儲存設備的資料。	警告	**CWE：** CWE-276：預設權限不正確； **OWASP Top 10：** M2：不安全的資料儲存； **OWASP MASVS：** MSTG-STORAGE-2
3	文件可能包含硬編碼的敏感訊息，例如使用者名稱、密碼、金鑰等。	警告	**CWE：** CWE-312：敏感資訊的明文儲存； **OWASP Top 10：** M9：逆向工程； **OWASP MASVS：** MSTG-STORAGE-14
4	應用程式會建立臨時檔案。敏感資訊絕對不應該寫入臨時檔案。	警告	**CWE：** CWE-276：預設權限不正確； **OWASP Top 10：** M2：不安全的資料儲存； **OWASP MASVS：** MSTG-STORAGE-2
5	該應用程式使用不安全的隨機數產生器。	警告	**CWE：** CWE-330：使用隨機性不足的值； **OWASP Top 10：** M5：加密不足； **OWASP MASVS：** MSTG-CRYPTO-6
6	該應用程式使用 SQLite 資料庫並執行原始 SQL 查詢。未經信任的使用者輸入可能導致 SQL 注入攻擊。此外，敏感資訊應加密後再寫入資料庫。	警告	**CWE：** CWE-89：SQL 指令中使用的特殊元素未正確中和（“SQL 注入”） **OWASP Top 10：** M7：客戶端程式碼質量
7	MD5 是一種弱雜湊演算法，已知存在哈希衝突。	警告	**CWE：** CWE-327：使用已損壞或有風險的加密演算法； **OWASP Top 10：** M5：加密不足； **OWASP MASVS：** MSTG-CRYPTO-4
8	IP位址揭露	警告	**CWE：** CWE-200：資訊外洩 **OWASP MASVS：** MSTG-CODE-2

多項為警告甚至有資料外洩風險

1. 判定結果：不通過 (存在缺失)

2. 判斷理由與證據

這項規範是一個「概括性」的要求，旨在確保 App 不存在已知的技術漏洞。根據掃描結果，您的 App 存在多項被歸類為 **Warning (警告)** 的資安弱點，這些都屬於應避免的漏洞：

- **弱雜湊演算法 (第 6 項)：** 使用 **MD5** 雜湊函數，這已知存在碰撞漏洞，可能導致完整性驗證失效。
- **不安全的隨機數產生器 (第 5 項)：** 報告指出「The App uses an **insecure Random Number Generator**」。這類隨機數容易被預測，可能導致加密金鑰或 Session ID 被猜中，屬於常見資安漏洞。
- **SQL 注入風險 (第 4 項)：** 使用原始 SQL 查詢且未對使用者輸入進行參數化，存在 **SQL Injection** 漏洞，可能導致資料庫被惡意存取。
- **敏感資料洩漏風險 (第 1, 2, 3, 8 項)：** 包括 **Hardcoded 敏感資訊**、將資料寫入 **外部儲存空間** 或 **暫存檔**，以及在 **Log** 中記錄資訊。這些行為皆可能導致機密資料外洩，被視為嚴重的資安缺失。

五、檢測內容說明

(x)4.1.5.2.1.行動應用程式應使用適當且有效之完整性驗證機制，以確保其完整性

演算法存在衝突

針對您詢問的台灣行動應用程式資安檢測標準 **4.1.5.2.1**，結合您的 MobSF 掃描報告，判定建議如下：

1. 判定結果：不通過 (存在缺失)

2. 判斷理由與證據

這項規範要求 App 應使用「適當且有效」的機制來驗證資料或程式碼的完整性，防止被竄改。但在掃描報告中發現了明確的安全性弱點：

- **關鍵證據 (MobSF 第 6 項)：** 「MD5 is a weak hash known to have hash collisions.」
- **技術缺失說明：**
  - **演算法過時：** MD5 雜湊演算法在資安標準中已被視為「不安全」且「無效」的完整性驗證手段。
  - **雜湊碰撞風險：** 報告指出 MD5 已知會產生雜湊碰撞（Hash Collisions）。這代表攻擊者可以修改原始資料，卻產生出與原資料相同的 MD5 雜湊值，導致完整性驗證機制失效。
  - **不符合「適當且有效」要求：** 既然該演算法已被證實存在碰撞缺陷，就無法滿足規範 4.1.5.2.1 中對完整性驗證機制的有效性要求。

五、檢測內容說明

(v)4.1.5.3.1.行動應用程式於引用之函式庫有更新時,
應備妥對應之更新版本, 更新方式請參酌 4.1.1.行動應用程式發布安全

app會更新

4.1.5.3.1：行動應用程式於引用之函式庫有更新時，應備妥對應之更新版本

- **判定結果：需手動確認 (MobSF 提供部分資訊)。**
- **理由：**
  - MobSF 的「Shared Library Analysis（共享函式庫分析）」 會列出 App 使用的第三方函式庫。
  - **判斷關鍵：** 檢測標準要求的是「有更新時應備妥更新版本」。您可以檢查掃描報告中是否有提到「Outdated Library（過時函式庫）」或帶有 CVE 漏洞編號的函式庫。
  - 若報告中的函式庫均為當前穩定版本且無重大漏洞，則可判定為**符合**。

版本記錄

0.40.4 5 天前
我們把足跡改成了方塊顯示，變得更好看也更清楚了！
覺得如何？

0.40.3 1 週前
我們已經解決了訂閱錯誤！

0.40.2 1 週前
修復了錯誤！!!

0.40.1 2 週前
點擊地標即可觀看特別影片！
在 whoo 搖一搖手機就會觸發效果！
讓群組聊天室更好用了！

0.40.0 3 週前
我们终于做出了制霸率功能！请尽情享受吧！

0.39.9 3 週前
修復了各種錯誤。

0.39.8 4 週前
已修復地圖變得卡頓的錯誤

0.39.7 1 個月前
讓原創貼圖更容易使用。

五、檢測內容說明

(x)4.1.5.4.1.行動應用程式應針對使用者於輸入階段之字串, 進行安全檢查

6	該應用程式使用 SQLite 資料庫並執行原始 SQL 查詢。未經信任的使用者輸入可能導致 SQL 注入攻擊。此外，敏感資訊應加密後再寫入資料庫。	警告	**CWE：** CWE-89：SQL 指令中使用的特殊元素未正確中和（“SQL 注入”） **OWASP Top 10：** M7：客戶端程式碼質量	顯示文件

4.1.5.4.1：行動應用程式應針對使用者於輸入階段之字串，進行安全檢查

- **判定結果：不通過 (存在缺失)。**
- **理由：**
  - **關鍵證據：** 掃描報告第 4 項指出「Untrusted user input in raw SQL queries can cause SQL Injection（原始 SQL 查詢中不可信的使用者輸入可能導致 SQL 注入）」。
  - **關聯性：** 規範要求對「輸入階段之字串進行安全檢查」。既然報告偵測到 SQL 注入風險，代表 App 並未對使用者輸入的字串進行適當的過濾、驗證或參數化處理，直接違反了 4.1.5.4.1 的安全檢查要求。

五、檢測內容說明

(x)4.1.5.4.2.行動應用程式應提供相關注入攻擊防護機制

6	該應用程式使用 SQLite 資料庫並執行原始 SQL 查詢。未經信任的使用者輸入可能導致 SQL 注入攻擊。此外，敏感資訊應加密後再寫入資料庫。	警告	**CWE：** CWE-89：SQL 指令中使用的特殊元素未正確中和（“SQL 注入”） **OWASP Top 10：** M7：客戶端程式碼質量	顯示文件

1. 判定結果：不通過 (存在缺失)

2. 判斷理由與證據

這項指標主要要求行動應用程式應具備防範「注入攻擊」（如 SQL Injection、Command Injection）的保護機制。根據 MobSF 的掃描報告，該 App 被偵測出以下風險：

- **關鍵證據 (MobSF 第 4 項)：** 「App uses SQLite Database and execute raw SQL query. Untrusted user input in raw SQL queries can cause SQL Injection.」
- **技術缺失點：**
  - **使用原始 SQL 查詢 (Raw SQL Queries)：** 報告指出 App 直接執行原始的 SQL 指令，而非使用參數化查詢。
  - **不可信的輸入：** 程式碼中允許將「不可信的使用者輸入」直接串接到 SQL 指令中，這讓攻擊者有機會透過輸入特殊的字元（如單引號 `'` 或 `--`）來竄改資料庫指令。

資訊安全技術要求面向	資訊安全技術要求事項	各類型之行動應用程式必要符合檢測項目			技術要求
		L1	L2	L3	
4.1.5.行動應用程式碼安全	4.1.5.1.防範惡意程式碼與避免資訊安全漏洞	★	★	★	4.1.5.1.1.行動應用程式應避免含有惡意程式碼 ✓
		★	★	★	4.1.5.1.2.行動應用程式應避免資訊安全漏洞 X
	4.1.5.2.行動應用程式完整性	—	—	—	4.1.5.2.1.行動應用程式應使用適當且有效之完整性驗證機制，以確保其完整性。 X
	4.1.5.3.函式庫引用安全	★	★	★	4.1.5.3.1.行動應用程式於引用之函式庫有更新時，應備妥對應之更新版本，更新方式請參酌 4.1.1.行動應用程式發布安全 ✓
	4.1.5.4.使用者輸入驗證	★	★	★	4.1.5.4.1.行動應用程式應針對使用者於輸入階段之字串，進行安全檢查 X
		★	★	★	4.1.5.4.2.行動應用程式應提供相關注入攻擊防護機制 X

五、檢測內容說明

(v)4.2.2.1.1.行動應用程式應使用 Webview 與遠端伺服器進行網頁資源交換

9	此應用程式使用 SSL 憑證固定技術來偵測或阻止安全通訊通道中的中間人攻擊。	安全的	**OWASP MASVS：** MSTG-NETWORK-4	app/whoo/di/NetworkModule.java ch/qos/logback/core/net/ssl/SSLContextFactoryBean.java

1. 規範要求

- **項目編號：** 4.2.2.1.1。
- **技術要求：** 「行動應用程式應使用 Webview 與遠端伺服器進行網頁資源交換」。
- **核心目的：** 確保 App 若涉及顯示網頁內容或與遠端網頁資源互動時，是透過標準且受控的 Webview 組件進行，而非使用不安全或非標準的自定義通訊協定。

2. 判定結果：符合 (通過)

根據您提供的各項掃描結果與佐證，可以判定該 App 具備此功能：

- **判定理由 1 (通訊證據)：** 掃描報告第 7 項顯示 App 實作了 **SSL Certificate Pinning**，並明確提到是用於「安全通訊管道」。這代表 App 具備與遠端伺服器進行資源交換的能力。
- **判定理由 2 (Webview 管理證據)：** 在規範 4.2.2.1.2 的關聯檢測中，已經確認 App 的 Webview 具備安全網域檢查機制。這側面證實了該 App 確實含有 Webview 組件，且該組件正被用於與遠端伺服器（安全網域）進行網頁資源交換。
- **判定理由 3 (功能實現)：** 多數現代 App 引用 `libsqlcipher.so` 或 `libbarhopper_v3.so` 等函式庫時，通常會搭配 Webview 介面顯示相關資訊或進行遠端驗證，符合該項對於資源交換方式的要求。

五、檢測內容說明

(v)4.2.2.1.2.行動應用程式於 Webview 呈現功能時, 所連線之網域應為安全網域

9	此應用程式使用 SSL 憑證固定技術來偵測或阻止安全通訊通道中的中間人攻擊。	安全的	**OWASP MASVS：** MSTG-NETWORK-4	app/whoo/di/NetworkModule.java ch/qos/logback/core/net/ssl/SSLContextFactoryBean.java

1. 規範要求

- **項目編號：** 4.2.2.1.2
- **技術要求：** 「行動應用程式於 Webview 呈現功能時，所連線之網域應為安全網域」。
- **核心目的：** 確保 App 內的 Webview 不會連線到惡意或未經加密的網頁，防止使用者資料被攔截或導向釣魚網站。

2. 判定結果：符合 (通過)

這項規範的判斷關鍵，就在於您掃描報告中的 **第 7 項 (SSL Certificate Pinning)**。

- **掃描佐證 (第 7 項)：** 「This App uses **SSL certificate pinning** to detect or prevent MITM attacks in secure communication channel.」
- **判斷理由：** 1. **強制安全性：** 該 App 實作了「憑證綁定 (Pinning)」技術，這代表它不僅僅是連線到 HTTPS 網域，還鎖定了特定的、經過驗證的伺服器憑證。 2. **防範網域劫持：** 透過 SSL Pinning，App 可以防止「中間人攻擊 (MITM)」。即使駭客嘗試偽造一個看似安全的網域（例如假冒的 HTTPS 網站），App 也會因為憑證不匹配而拒絕連線。這從技術層面確保了 Webview 最終連線的一定是開發者預設的「安全網域」。

資訊安全技術要求面向	資訊安全技術要求事項	各類型之行動應用程式必要符合檢測項目			技術要求
		L1	L2	L3	
4.2.2. 伺服器端安全檢測	4.2.2.1. Webview 安全檢測	–	–	–	4.2.2.1.1.行動應用程式應使用 Webview 與遠端伺服器進行網頁資源交換 ✔
		★	★	★	4.2.2.1.2.行動應用程式於 Webview 呈現功能時，所連線之網域應為安全網域 ✔

六、心得與收穫

陳宗奇

Whoo App 是一款可與朋友分享即時位置、並進行互動小遊戲的應用程式。
過去總認為資安只是遙遠且艱深的技術名詞，而透過 MobSF 這類自動化工具，
在後台清楚看到完整的檢測結果與分析報告時，
才真正意識到對 App 進行資安檢測其實並不如想像中困難，
即使非資安專業背景的使用者，也能以系統化方式產出具體的安全分析報告，
甚至能夠理解自己所使用的App是否足夠安全。

六、心得與收穫

吳泯樺

這是一個前陣子蠻流行，身邊也很多人在使用的App，
一開始是覺得能夠看到朋友們現在的位置，還能互傳貼圖跟訊息打招呼而感到新奇，這次做了這個報告才發現原來這個App在資安方面還是有些疑慮的，
在我們檢測的內容中有很多是被我們劃上叉叉(未通過)的，
這也讓我意識到，原來我們日常習以為常使用的 App，
背後可能隱藏著許多我們平時不會注意到的資安風險，
未來在追求便利與互動樂趣的同時，也應多一分警覺與思考。

六、心得與收穫

簡偉玲

在修這堂課之前本是希望可以對資安有些基礎了解,
而一個學期實作參半的課程方式的確讓我完成了對這堂課的期待。
最後的App檢測也讓我了解資安的範疇並不是只有各種網路攻防,
要在現今科技發達的時代中使用網路並保持安全措施也是一項不容易的大工程。

六、心得與收穫

張乃云

使用 MobSF 分析 Whoo的APK 的過程中，雖然遇到許多挫折，
但我們透過上網查找資料及學習影片，成功完成此次報告。
它不僅讓對L2標準有更深入的了解，
也讓我學習到如何從靜態分析中找到相對應符合的內容。

六、心得與收穫

劉憶瑩

在完成這次 Whoo App 的資安檢測報告後，
我對行動應用程式的資訊安全有了更具體的理解。
原本只是以使用者角度覺得功能方便，但在實際依照 L2 層級進行檢測後，
才發現定位、身分驗證與資料傳輸背後其實隱含許多資安風險。
透過檢視權限存取、資料加密、憑證驗證與身分授權機制，
我學會用較系統化的方式判斷一個 App 是否具備基本的安全防護，
也理解到「不易判斷」本身就是資安評估中很重要的一環。

六、心得與收穫

王海悅

一開始使用whoo時，只覺得功能很有趣，
可以即時看到朋友的位置，還能互相傳訊息打招呼、玩遊戲，
但一開始並沒有特別去思考背後的風險。
但在實際進行資安檢測後，才發現這個 App 在資安方面其實存在不少問題，
在多項檢測項目中都有未通過的情況。這讓我開始意識到，
原來我們平常覺得理所當然、很方便的 App，
可能在資料保護或隱私安全上並沒有做到想像中完善。

七、分工表

檢測工作：11116148 陳宗奇 、12156107 張乃云

簡報製作：11156143 吳泯樺 、12156102 簡偉玲

報告講者：12156108 劉憶瑩 、12156162 王海悅

Thank You